

FedF1rst Security Assessment



Mohamad Abdelnaby
6/26/2024



Section One: Develop a hardening strategy



Windows 10 Hardening

1. System Updates disabled

Disabled Automatic Updates.

primary way to keep your systems secure is to Update frequently.

Microsoft has removed the manual setting for updates so Automatic is the only remaining option.

However, there are settings that can be configured. For instance, you can pause updates and uninstall problematic updates. If you have multiple PCs it is recommended to use a centralized updating solution such as SCCM or Intune.

2. Virus & Threat Protection settings not configured

Tamper Protection is disabled by the administrator, the administrator has to either install an AV solution or use the Windows 10 one to its full capabilities, I recommend enabling all AV from Windows 10.

3. Firewall is Disabled

Windows Firewall is off, it is highly recommended that you use it in conjunction with your network firewall. Start with the Default Rules then allow additional rules as needed. As with everything in security, document your changes.



Windows 10 Hardening

4. Autoplay not configured

Autoplay plays a huge part in preventing malware from starting automatically, my recommendation is to configure the autoplay feature as per the organization and their needs. I would configure it so it asks the user every time for needed software and would disable the rest entirely, implementing PoLP.

5. Guest Account is enabled

It is best to disable the guest account completely

6. Password Policy not configured

Minimum password length is 0 chars, password must meet complexity requirements is not configured.

Password Best Practices

- History
 - Don't allow usage of the last 3 passwords.
- Length
 - 15 characters will appease most compliance requirements.
- Reversible Encryption
 - Don't do it! It would allow the decryption of any password that was obtained by adversaries.
- Age
 - Change frequently. A common tradeoff is a longer password for fewer changes per year.
- Complexity
 - Generally, require 3 of the 4 character types.



MacOS Hardening

1. Accounts

Local admins are common and they have admin access, just add them to Active Directory Domains or MDM (JAMF)

2. Filevault

Full disk encryption controlled by Key or password and can be turned on via MDM

3. Firewall

Firewall is shipped as turned off just enable it.



MacOS Hardening

4. Firmware

By default, a Mac will boot to external devices potentially compromising the system.
By adding a firmware password you can prevent this. It is also transparent to the user in daily usage.

5. Applications

Lockdown Macs with Gatekeeper application, to control where applications can be installed from

6. Mac updates

Make sure to check OS updates as well as appstore updates frequently.



Section Two: Create Security Policies



Email Policy

1. All users have to take Phishing training and always lookout for any phishing attempts and immediately report if found or in doubt
2. The company is not responsible for any Data Exfiltration and employees who engage in such acts are in threat of facing termination, legal fines/sanctions and legal actions if deemed necessary
3. Employees are to change their passwords every 30 days.
4. Employees should not access their emails outside of company devices and/or outside of work hours.
5. The company is not responsible for any form of Business Email Compromise (BEC)
6. The company prohibits any distribution of malware links through company's email. Action will be taken against employees who distribute malware through email



BYOD Policy

1. Acceptable Smartphones: Only Apple and Android Based smartphones.

2. Acceptable Laptops: Any make/model as long as it is running Windows 11 or macOS

No Linux at this time to save the IT team from troubleshooting issues frequently.

3. Smartphones must be new enough to receive current security updates.
Laptops: Must always be up to date with security patches

4. Mobile phones must have a strong password or passcode that includes a screen lock.

Laptops: A strong password of 15 characters must be used

5. Upon dismissal, the firm reserves the right to remotely wipe the mobile device at any time.

6. The laptop must have an updated antivirus application. If necessary, a license can be provided.



Section Three: Self Assessment



Windows Desktop Compliance

Windows 10 Regulatory Requirement	Met/Not Met
Built-In Administrator account is disabled	Not Met
Windows Firewall is enabled	Not Met
Automatic updates are enabled	Not Met
User Account Control (UAC) is enabled	Not Met
Strong password policies are enforced	Not Met
Guest account is disabled	Not Met
System logging and auditing are enabled	Not Met
Windows Defender Antivirus is enabled and up to date	Not Met
Remote Desktop Services are configured securely	Met
Internet Explorer Enhanced Security Configuration (IE ESC) is enabled	Not Met
USB ports are disabled or restricted to authorized devices only	Not Met
Network access controls are implemented, including VLAN segmentation and port security	Not Met
Remote Registry service is disabled	Met
Windows Updates are configured to download and install updates automatically	Not Met



Windows Desktop Compliance

Built-In Administrator account is disabled: Disable the built-in Admin account
Windows Firewall is enabled: Enable and configure Windows Firewall, the general rule is to deny and enable as needed
Automatic updates are enabled: Enable Windows Automatic updates to stay up-to-date with the latest security patches
User Account Control (UAC) is enabled: Enable User Access Controls from the control panel
Strong password policies are enforced: Implement Strong Password policies History: Don't allow usage of the last 3 passwords. Length: 15 characters will appease most compliance requirements. Age: Change frequently. A common tradeoff is a longer password for fewer changes per year. Complexity: Generally, require 3 of the 4 character types.
Guest account is disabled: Disable the guest account
System logging and auditing are enabled: Enable and configure system logs
Windows Defender Antivirus is enabled and up to date: Enable and configure Windows Defender AV
Internet Explorer Enhanced Security Configuration (IE ESC) is enabled: Enable from Remote services
USB ports are disabled or restricted to authorized devices only: Configure from Control Panel
Network access controls are implemented, including VLAN segmentation and port security: Secure the ports as there are multiple TCP/UDP ports open, rule is to deny all and allow as needed
Windows Updates are configured to download and install updates automatically: Enable from Settings



CentOS Compliance

CentOS CMMC Requirements	Met/Not Met
Current on security updates	Not Met
Ensure separate partition exists for /var	Not Met
Disable Automounting of drives	Met
Ensure AIDE is installed	Not Met
Ensure daytime services are not enabled	Met
Ensure echo services are not enabled	Met
Ensure tftp server is not enabled	Met
Ensure CUPS is not enabled	Met
Ensure DHCP Server is not enabled	Met
Ensure FTP Server is not enabled	Met
Ensure Samba is not enabled	Met
Ensure TCP Wrappers is installed	Not Met
Ensure DCCP is disabled	Met
Ensure iptables is installed	Met
Ensure audit log storage size is configured	Met
Ensure audit logs are not automatically deleted	Not Met



Section Four: Cloud Management



Windows Server Build Sheet

1. Use Secure Connections

The SSH protocol is recommended for this purpose as it encrypts all data transmitted between the client and the server.

change the default SSH port from 22 to a random, non-privileged port number between 1024 and 32,767.

2. Set up SSH Keys Authentication

Instead of a password, you can authenticate to an SSH server using a pair of SSH keys. This method provides a more secure alternative to traditional logins, as these keys offer cryptographic strength that far exceeds typical password capabilities, such as those provided by RSA 2048-bit encryption.

3. Secure File Transfer Protocol (FTPS)

Utilize File Transfer Protocol Secure (FTPS) to transfer files securely to and from a server. FTPS encrypts data files and authentication information using command and data channels.

4. Implement SSL Certificates

Secure your web administration areas and forms with SSL/TLS certificates. These certificates encrypt information passed between two systems via the internet. SSL/TLS can be used in both server-client and server-server communication.

5. Monitor Login Attempts

Protect your server against brute-force attacks by using intrusion prevention software to monitor login attempts.

Intrusion prevention software oversees all log files and detects suspicious login attempts. If the number of failed login attempts exceeds a predetermined threshold, the software blocks the IP address temporarily or permanently. This automated and preemptive action protects your server against unauthorized access.



Windows Server Build Sheet

6. Manage User Access

Given this high level of access, root accounts can be dangerous in the wrong hands. Therefore, it is a best practice to disable root login for SSH altogether.

7. Implement Strong Firewall Policies

Use Linux firewall tools like GFW, an intuitive graphical user interface for managing iptables, or iptables itself to configure rules that restrict access to your server and manage incoming and outgoing traffic. For Windows servers, consider using Windows Defender Firewall with Advanced Security.

8. Use Passphrases for Server Passwords

Passphrases are typically longer and include spaces between words, making them easier to remember and harder to crack.

For example, a password passphrase may be: Ilove!EatingPizzaAt1676MainSt.

This passphrase exceeds typical password lengths and includes a mix of upper and lowercase letters, numbers, and special characters.

9. Update and Upgrade Software Regularly

Keep your server software up to date to protect against vulnerabilities found in older versions. Regularly update your server control panel, content management systems, and associated plugins.

10. Backup Your Server

Store encrypted backups of your critical data offsite
Whether you have automated backup jobs or do them manually, performing regular backups must become a routine precautionary measure.



Enhancing Cloud Security with CASB

1. Shadow IT assessment and management

CASBs deliver visibility into all cloud applications, sanctioned and unsanctioned. Enterprises can employ a CASB to obtain a comprehensive picture of cloud activity and enact security measures accordingly.

2. Granular cloud usage control

CASBs offer detailed management of cloud usage with strong analytics. Enterprises can limit or allow access based on employee status or location, and can govern specific activities, services, or applications.

3. Data loss prevention (DLP)

A CASB's DLP capabilities help security teams protect sensitive information like financial data, proprietary data, credit card numbers, health records, or social security numbers. A CASB solution can enable policies that prevent unauthorized sharing of this data.

4. Risk visibility

CASBs allow enterprises to assess the risk of unsanctioned applications and make access decisions accordingly.

5. Threat prevention

CASBs detect unusual behavior across cloud applications, identifying ransomware, compromised users, and rogue applications. CASBs can analyze high-risk application use and automatically remediate threats, limiting an organization's risk.